

COMPTE RENDU

TP1.1 CHAPITRE 1 : CYBER SECURITE

1. Présentation de nmap

a-Définition et rôle de l'outil

Nmap (Network Mapper) est un scanner réseau open-source de référence, utilisé par les administrateurs système, les ingénieurs réseau et les pentesters depuis 1997. Il permet de cartographier l'infrastructure d'un réseau, d'identifier les hôtes actifs, les ports ouverts, les services en écoute ainsi que les systèmes d'exploitation des machines cibles.

Ses fonctions principales sont :

- Découverte d'hôtes (Host Discovery) : identifier les machines actives sur un réseau
- Scan de ports : déterminer l'état de chaque port (ouvert, fermé, filtré)
- Détection de services et versions : identifier les démons applicatifs et leurs versions
- Détection d'OS : fingerprinting du système d'exploitation

b-Contexte d'utilisation

Nmap s'utilise dans plusieurs contextes professionnels légitimes :

- Audit de sécurité : Inventaire des services exposés, vérification de la surface d'attaque
- Tests de pénétration : Phase de reconnaissance active (Phase 2 du pentest)
- Administration réseau : Inventaire des hôtes, vérification de configuration firewall

2-Analyse des Commandes Utilisées

Nmap s'utilise avec plusieurs options parmi lesquelles nous avons :

Nmap -sn suivis de l'IP du réseau distant : L'option -sn demande à Nmap d'effectuer uniquement une découverte d'hôtes sans scanner les ports. Nmap envoie une combinaison de paquets ICMP Echo Request, TCP SYN vers le port 443, TCP ACK vers le port 80, et ICMP Timestamp Request pour déterminer si un hôte est actif. On l'utilise pour connaître le nombre d'hôte connecter au réseau ainsi que leur ip.

```
Session Actions Éditer Vue Aide
5 packets transmitted, 5 received, 0% packet loss, time 4004ms
rtt min/avg/max/mdev = 1.113/1.347/1.959/0.313 ms

(seliore@kali)-[~]
$ ping 192.168.56.20
PING 192.168.56.20 (192.168.56.20) 56(84) bytes of data.
64 bytes from 192.168.56.20: icmp_seq=1 ttl=128 time=1.73 ms
64 bytes from 192.168.56.20: icmp_seq=2 ttl=128 time=1.27 ms
64 bytes from 192.168.56.20: icmp_seq=3 ttl=128 time=1.04 ms
64 bytes from 192.168.56.20: icmp_seq=4 ttl=128 time=5.90 ms
64 bytes from 192.168.56.20: icmp_seq=5 ttl=128 time=1.65 ms
64 bytes from 192.168.56.20: icmp_seq=6 ttl=128 time=3.40 ms
64 bytes from 192.168.56.20: icmp_seq=7 ttl=128 time=0.976 ms
64 bytes from 192.168.56.20: icmp_seq=8 ttl=128 time=2.81 ms
^C
--- 192.168.56.20 ping statistics ---
8 packets transmitted, 8 received, 0% packet loss, time 7009ms
rtt min/avg/max/mdev = 0.976/2.346/5.903/1.564 ms

(seliore@kali)-[~]
$ sudo nmap -sn 192.168.56.0/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-16 13:39 +0200
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.10
Host is up (0.00097s latency).
MAC Address: 08:00:27:50:FC:C3 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.20
Host is up (0.00085s latency).
MAC Address: 08:00:27:60:A7:63 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.30
Host is up.
Nmap done: 256 IP addresses (3 hosts up) scanned in 1.99 seconds

(seliore@kali)-[~]
$
```

Nmap -sS (SYN Scan) suivis de l'hôte distant à analyser : Le SYN Scan est le scan par défaut et le plus populaire de Nmap. Il envoie un paquet TCP SYN à chaque port cible. Si le port est ouvert, le serveur répond SYN/ACK — Nmap envoie alors un RST (reset) sans compléter la connexion TCP. C'est pourquoi on l'appelle aussi 'half-open scan' : la connexion n'est jamais établie complètement. On l'utilise pour détecter quels sont les ports ouverts sur un hôte.

```
(seliore@kali)-[~]
$ sudo nmap -sS 192.168.56.20
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-16 14:00 +0200
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled
Nmap scan report for 192.168.56.20
Host is up (0.0023s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
MAC Address: 08:00:27:60:A7:63 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 4.88 seconds

(seliore@kali)-[~]
$
```

Nmap -sV suivis de l'IP de l'hôte distant à analyser : L'option -sV active la détection de version des services. Nmap se connecte aux ports ouverts et envoie des sondes (probes) spécifiques pour obtenir la bannière du service. Il compare ensuite les réponses à sa base de données nmap-serviceprobes (plus de 7 000 signatures) pour identifier le service et sa version exacte. En plus la détection des numéros de ports et des services, il est utilisé pour la détection de **la version des services disponibles ainsi que quelques informations sur le système d'exploitation.**

```
(seliore@kali)-[~]
$ sudo nmap -sV 192.168.56.20
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-16 14:11 +0200
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled
Nmap scan report for 192.168.56.20
Host is up (0.0015s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds Microsoft Windows 7 - 10 microsoft-ds (workgroup:
MAC Address: 08:00:27:60:A7:63 (Oracle VirtualBox virtual NIC)
Service Info: Host: WINDOWS; OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://
Nmap done: 1 IP address (1 host up) scanned in 11.75 seconds

(seliore@kali)-[~]
$
```

Nmap -O suivis de l'IP de l'hôte distant à analyser : L'option -O active la **détection du système d'exploitation.** Nmap utilise des techniques de TCP/IP fingerprinting : il envoie une série de sondes spécialement conçues et analyse les subtilités de la réponse (TTL, taille de fenêtre TCP, bits DF, options TCP, numéros de séquence ISN...). Chaque OS implémente la pile TCP/IP légèrement différemment. Ces variations constituent une empreinte unique.

```
(seliore@kali)-[~]
$ sudo nmap -O 192.168.56.20
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-16 14:13 +0200
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.20
Host is up (0.0015s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
135/tcp   open  msrpc        Microsoft Windows 11|10|2022|Phone|2008 (97%)
139/tcp   open  netbios-ssn  Microsoft Windows 11 21H2 (97%)
445/tcp   open  microsoft-ds Microsoft Windows 10 (92%), Microsoft Windows Server 2022 (91%), Microsoft Windows 10 1607 (91%), Microsoft Win
MAC Address: 08:00:27:60:A7:63 (Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose|phone
Running (JUST GUESSING): Microsoft Windows 11|10|2022|Phone|2008 (97%)
OS CPE: cpe:/o:microsoft:windows_11 cpe:/o:microsoft:windows_10 cpe:/o:microsoft:windows_server_2022 cpe:/o:microsoft:windows cpe:/o:microsoft:windows_server_2008::sp1
Aggressive OS guesses: Microsoft Windows 11 21H2 (97%), Microsoft Windows 10 (92%), Microsoft Windows Server 2022 (91%), Microsoft Windows 10 1607 (91%), Microsoft Win
dows Phone 7.5 or 8.0 (88%), Microsoft Windows Server 2008 SP1 (88%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.77 seconds
```

Nmap –A suivis de l'IP de l'hôte distant à analyser : cette option est la plus complète et la plus bruyantes car elle combine toutes les options précédentes ajouter auxquelles s'ajoute traceroute et scripts.

```
Host script results:
| smb2-time:
|   date: 2026-04-16T12:15:13
|_  start_date: 2026-04-16T11:21:03
| smb-security-mode:
|_  account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
| smb-os-discovery:
|_  OS: Windows 10 Pro 15063 (Windows 10 Pro 6.3)
|   OS CPE: cpe:/o:microsoft:windows_10::-
|   Computer name: windows
|   NetBIOS computer name: WINDOWS\x00
|   Workgroup: WORKGROUP\x00
|_  System time: 2026-04-16T14:15:13+02:00
| smb2-security-mode:
|_  3.1.1:
|_    Message signing enabled but not required
|_ clock-skew: mean: -39m47s, deviation: 1h09m16s, median: 11s
|_ nbstat: NetBIOS name: WINDOWS, NetBIOS user: <unknown>, NetBIOS MAC: 08:00:27:60:a7:63 (Oracle VirtualBox virtual NIC)

TRACEROUTE
HOP RTT      ADDRESS
1   2.67 ms  192.168.56.20

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 55.47 seconds
```

3-Résultats Obtenus

- **Machine détecter** : nous avons détecter 5 hôtes parmi lesquelles nous avons nos trois machines virtuelles (kali, Ubuntu et Windows), la machine réelle ainsi que l'adresse de la passerelles Virtual box.
- **Ports ouverts et services** : nous avons Détecter 3 ports ouvert sur Windows : le port 135 qui correspond au service RPC, le port 139 qui correspond au services NetBIOS-sn et le port 445 qui correspond au services samba. Sur Ubuntu par défaut aucun port n'est ouvert.

4-Analyse de Sécurité

- **Services dangereux** : le services Microsoft qui écoute sur le port 445 TCP et qui correspond au SMB est un service dangereux car son port est ouvert.
- Le port 445 devrait être fermé ainsi que le port 139
- L'entreprise risque de se faire pirater grâce à l'utilisation de ces ports ouvert.

5-Utilisation Avancée de Nmap

- **Option -p-** : Par défaut, Nmap scanne uniquement les 1 000 ports les plus communs selon sa base de données **nmap-services**. L'option -p- (ou -p 1-65535) force le scan des 65 535 ports TCP, du port 1 au port 65535. Cela permet de détecter les services qui se cachent intentionnellement sur des ports non standards (technique courante pour masquer des backdoors ou des services d'administration). Il permet de faire :
 - Le Pentest : identifier les backdoors ou services d'administration cachés sur des ports nonstandards ;
 - L'Audit complet : s'assurer qu'aucun service non autorisé n'écoute sur le serveur ;
 - Il est possible de spécifier le port à scanner en utilisant comme suit : **nmap -p « numéro de port » ip de l'hôte distant**
- **Option --script vuln** : L'option --script vuln exécute tous les scripts de la catégorie 'vuln' soit plus de 100 scripts qui testent automatiquement les vulnérabilités connues sur chaque service détecté.

Cas d'usage : il peut être utilisé pour détecter une vulnérabilité connue sur un système précis et automatiser la recherche de vulnérabilité.

```
(seliore@kali)-[~]
$ sudo nmap --script vuln 192.168.56.20
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-16 14:18 +0200
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.20
Host is up (0.0013s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
MAC Address: 08:00:27:60:A7:63 (Oracle VirtualBox virtual NIC)

Host script results:
|_smb-vuln-ms10-061: NT_STATUS_ACCESS_DENIED
|_smb-vuln-ms10-054: false
|_samba-vuln-cve-2012-1182: NT_STATUS_ACCESS_DENIED

Nmap done: 1 IP address (1 host up) scanned in 19.45 seconds
(seliore@kali)-[~]
$
```

```
|_ https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|_ https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|_smb-vuln-ms10-054: false

Nmap done: 1 IP address (1 host up) scanned in 101.45 seconds
```

On peut voir qu'une des vulnérabilités de ce système est le protocole smb de samba.

- **Option -T4 — Contrôle de la Vitesse** : Nmap dispose de 6 niveaux de timing (T0 à T5) qui contrôlent la vitesse et l'agressivité du scan. Ces templates ajustent plusieurs paramètres simultanément : délai entre les sondes, timeout des connexions, nombre de tentatives, et débit réseau. Le bon choix de timing est crucial pour équilibrer vitesse, fiabilité et discrétion. Plus les T évoluent plus le scan est rapide.

Cas d'usage : dans un lab virtuel, on peut utiliser le T4 ou T5 car rapide mais dans un environnement réel, il est préférable d'utiliser T0 ou T1 car lent et difficiles à détecter par les IDS et IPS